

Secure API – Week 4 Advanced Threat Detection

This project demonstrates a production-ready Express.js API with:

- **Rate Limiting** (global and login-specific) to mitigate brute-force attacks.
- **CORS** restriction using allowed origins.
- **API Key Authentication** for protected endpoints.
- **Security Headers** via Helmet, including a strict Content Security Policy (CSP) and HSTS (enforced in production).
- **Intrusion Detection** with Fail2Ban that monitors failed login attempts and bans offending IPs.

Tech Stack

- Node.js / Express
- express-rate-limit
- helmet, cors
- Fail2Ban (for server-level monitoring)

Getting Started

Prerequisites

- Node.js (v14+)
- Linux server (for Fail2Ban) – optional for local testing

Installation

1. Clone the repository:

```
``bash
```

```
https://github.com/FahadMal1k/DevelopersHub/tree/main/Task2/Task2/secure-api
```

```
cd secure-api
```

2. Install dependencies:

```
bash
```

```
npm install
```

3. Copy `.env.example` to `.env` and set your variables:

```
bash
```

```
cp .env.example .env
```

- `API_KEYS`: comma-separated list of valid keys

- `ALLOWED_ORIGIN`: comma-separated list of allowed CORS origins
- `NODE_ENV`: set to `production` to enable HSTS

4. Start the server:

`bash`

`npm start`

For development with auto-restart:

`bash`

`npm run dev`

API Endpoints

Method	Endpoint	Description	Auth Required
GET	/api/public	Public test endpoint	No
POST	/api/login	Login (returns fake token)	No
GET	/api/protected	Protected endpoint	API Key

Authentication: Include `x-api-key: your-api-key` in the request headers.

Rate Limiting

- Global: 100 requests per 15 minutes per IP.
- Login: 10 attempts per 5 minutes per IP.

Fail2Ban Integration (Server Side)

1. Install Fail2Ban on your server.
2. Copy the provided `jail.local` and `filter.d/api-auth.conf` into `/etc/fail2ban/`.
3. Ensure your application logs failed login attempts to `/var/log/api/access.log`.
4. Restart Fail2Ban: `sudo systemctl restart fail2ban`.

The jail will ban IPs after 5 failed login attempts in 5 minutes for 1 hour.

Security Headers

- **Helmet** sets standard security headers.
- **CSP**: restricts script/style sources to 'self' (adjust as needed).
- **HSTS**: enabled only when `NODE_ENV=production`.

Deployment

Set `NODE_ENV=production` and ensure your server uses HTTPS (e.g., behind Nginx with SSL). The API will then enforce HSTS.

License

Final Checklist & Testing

- Test rate limiting: make >100 requests in 15 min to see `429 Too Many Requests`.
- Test CORS: try from an unallowed origin (should be blocked).
- Test API key: omit or send wrong key to protected endpoint → `401/403`.
- Test CSP: attempt to load an external script (should be blocked).
- Test Fail2Ban: simulate failed logins and check ban status with `sudo fail2ban-client status api-auth`.